exec.txt
TXT 12.05KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Análise Passo a Passo do Arquivo `exec.txt`

⚠️ AVISO IMPORTANTE

O conteúdo do arquivo é um **bytecode Python compilado** (`.pyc`) que foi renomeado/empacotado como `exec.txt` . Ao ler o bytecode, é possível reconstruir a lógica do script original. **Este é um artefato malicioso** — não execute, não abra em ambiente de produção.

1. Identificação do Formato

- O arquivo começa com `L��j` — magic number de bytecode Python (provavelmente Python 3.12+).
- Strings legíveis revelam código Python compilado: `OrderedDict` , `requests` , `psutil` , `hmac` , `hashlib` , `win32api` , `win32security` , `zipfile` , `tempfile` .
- Funções nomeadas: `notificar_instalacao` , `fechar_chrome` , `calculateHMAC` , `calc_supermac` , `get_extension_id` , `calculate_chrome_dev_mac` , `encode_to_install_time` , `download_and_extract_extension` , `add_extension` .

2. Análise das Funções — O que o script faz

🔴 `notificar_instalacao(extension_id, user, mensagem)`

- Envia **notificação via webhook** para `https://ntfy.sh/crimeorganizado000000000000caiunoob`
- Usa `requests.post` com `Content-Type: text/plain`

- **Exfiltra dados** (ID da extensão, usuário, mensagem) para servidor externo controlado pelo atacante.
- O nome do canal `crimeorganizado...` é explícito.

🔴 `fechar_chrome()`

- Usa `psutil.process_iter` para localizar processos com nome `chrome`
- Chama `proc.terminate()` e aguarda com `wait_procs`
- **Objetivo:** forçar o fechamento do Chrome para poder manipular arquivos de preferências sem conflito.

🔴 `calculateHMAC(...)` e `calc_supermac(...)`

- Implementam o cálculo de **HMAC-SHA256** usado pelo Chrome para proteger o arquivo `Secure Preferences`.
- `calc_supermac` gera o `super_mac` a partir de seed + mensagem, no formato `HMAC(seed, mensagem).hexdigest().upper()`.
- Isso é exatamente o algoritmo que o Chrome usa para validar integridade de preferências de extensões.
- **Objetivo:** forjar assinaturas válidas para que o Chrome aceite uma extensão não instalada legítimamente.

🔴 `get_extension_id(base, a, i, m)`

- Gera o ID da extensão a partir de bytes `utf-16-le`, convertendo cada caractere em hex e fazendo `chr(int(...))`.
- Emula o algoritmo de derivação de Extension ID do Chromium.

🔴 `calculate_chrome_dev_mac(...)`

- Serializa um dicionário JSON com `sort_keys=True` e calcula HMAC — novamente para forjar o MAC de desenvolvimento.

🔴 `encode_to_install_time(date)`

- Converte data para o formato de timestamp interno do Chrome (`datetime` → `total_seconds` → base 16/64), usado em `first_install_time` e `last_update_time`.

🔴 `download_and_extract_extension(url)`

- Baixa um ZIP de `https://antiddos-protection.net/_____/chrome_extension.zip`
- Extrai em diretório temporário via `tempfile.mkdtemp + zipfile.ZipFile.extractall`
- **Baixa e instala payload remoto** — comportamento clássico de dropper.

🔴 `add_extension(...)`

- Obtém o SID do usuário via `win32security.LookupAccountName + ConvertSidToStringSid`
- Lê `C:\Users\<user>\AppData\Local\Google\Chrome\User Data\Default\Secure Preferences`
- Injeta entrada em `extensions.settings` com:
  - `"account_extension_type":0`
  - `"api":["cookies","storage","tabs","scripting"]`
  - `"explicit_host":["<all_urls>"]`
  - `"incognito":true`
  - `"from_webstore":false`
  - `"location":4`
  - `"serviceworkerevents":["tabs.onUpdated"]`
- Recalcula e insere o `super_mac` forjado
- Ativa `extensions.ui.developer_mode = True`
- **Persistência + escalada de privilégios da extensão injetada.**

3. Indicadores de Maliciosidade (IOCs)

Indicador	Evidência
C2 / Webhook	`https://ntfy.sh/crimeorganizado000000000000caiunoob`
Download de payload	`https://antiddos-protection.net/_____/chrome_extension.zip`
Domínio suspeito	`antiddos-protection.net` (typosquatting de "anti-ddos")
Persistência	Injeta extensão em `Secure Preferences` do Chrome
Bypass de integridade	Forja `super_mac` e `dev_mac` com HMAC-SHA256
Privilégios	`cookies` , `tabs` , `scripting` , `<all_urls>` , `incognito:true`
Exfiltração	Envia ID da extensão + usuário para webhook
Anti-forense	Fecha Chrome antes de manipular preferências
Empacotamento	`.pyc` renomeado para `.txt` para evadir detecção

4. Fluxo de Execução Reconstruído

1. Gera/obtém Extension ID
2. Baixa `chrome_extension.zip` de `antiddos-protection.net`
3. Extrai em temp
4. Fecha todos os processos Chrome
5. Localiza `Secure Preferences` do usuário
6. Injeta a extensão em `extensions.settings`
7. Forja `super_mac` e `dev_mac` para bypassar validação
8. Ativa `developer_mode`
9. Envia notificação de sucesso para o webhook `ntfy.sh/crimeorganizado...`

5. Veredito

🚨 MALWARE — Trojan/Dropper (Chrome Extension Injector)

Classificação:

- **Tipo:** Trojan.Dropper / Browser Modifier / Extension Injector
- **Plataforma:** Windows (usa `win32api`, `win32security`)
- **Alvo:** Google Chrome (perfil do usuário)
- **Capacidades:** download de payload remoto, injeção de extensão maliciosa com permissões totais (`<all_urls>`, `cookies`, `scripting`, `incognito`), bypass de integridade via HMAC forjado, exfiltração para webhook, anti-forense (fecha Chrome).

Recomendações:

1. Não execute o arquivo.
2. Isole a máquina se ele já foi executado.
3. Verifique `Secure Preferences` do Chrome por extensões não reconhecidas.
4. Bloqueie os domínios `ntfy.sh` (canal específico) e `antiddos-protection.net`.
5. Remova extensões suspeitas e restaure o perfil do Chrome.
6. Execute varredura antimalware completa.

Conclusão: este arquivo é MALICIOSO e não deve ser executado em nenhuma circunstância.

Qual é a categoria principal deste malware?

Categoria Principal do Malware

🎯 Trojan.Dropper / Extension Injector

A categoria **principal** é **Trojan (Cavalo de Troia) do subtipo Dropper**, com função secundária de **Browser Modifier / Extension Injector**.

Por que essa é a categoria principal?

Característica observada	Categoria correspondente
Baixa payload remoto (`chrome_extension.zip` de `antiddos-protection.net`) e o instala	**Dropper** (baixa e executa/instala carga secundária)
Injeta extensão maliciosa no Chrome com permissões totais	**Extension Injector / Browser Modifier**
Forja `super_mac` / `dev_mac` para burlar integridade	**Defense Evasion** (técnica do Trojan)
Exfiltra dados para webhook (`ntfy.sh/crimeorganizado...`)	**Exfiltração (C2)** — comportamento acessório
Fecha o Chrome antes de manipular arquivos	**Anti-forense** — comportamento acessório

Classificação resumida

- **Categoria primária:** 🐴 **Trojan — Dropper**
- **Subcategoria/função:** 🌐 **Browser Hijacker / Extension Injector** (modifica o Chrome)
- **Plataforma:** Windows
- **Alvo:** Google Chrome

> Em resumo: é um **Trojan Dropper** cuja carga útil é uma **extensão maliciosa de Chrome**. O objetivo final não é criptografar arquivos (ransomware) nem se auto-replicar (worm), mas **instalar silenciosamente uma extensão com acesso total ao navegador** — por isso "Dropper/Extension Injector" é a categoria principal.